WORKSHOP NATIONAL EPSI BAC+5 — SESSION OCTOBRE 2026

PROJECT RESILIENCE-ALPHA : Dossier d'Ingénierie et de Gouvernance

Équipe / Groupe : G2 (Lenny BARRESI, Youssef HANSIL, Pierre MICHAUD-EYMOZ, Rohail ARSHAD) | **PC Hôte audité :** HDV0-INF-P08 (Windows 11 Pro, Core Ultra 9 185H, 31,42 Go RAM, RTX 4070, Docker Desktop v29.5.3 actif)

1.1 Synthèse Exécutive et Chaîne de Valeur Démontrée

Ce dossier présente la conception, l'implémentation, les essais réels et le cadre de gouvernance de **PROJECT RESILIENCE-ALPHA** : une plateforme de paiement fictive conteneurisée capable d'encaisser une attaque applicative contrôlée lancée depuis un second poste, de détecter l'anomalie par Machine Learning (*Isolation Forest*), d'engager une remédiation autonome confinée sans intervention humaine (*Zero-Touch Recovery*) et de prouver le rétablissement du service par une **nouvelle transaction métier réussie, persistée et comptablement intègre**.

Pilier du Sujet	Composants Livrés dans le Dépôt	Preuve Technique & Statut Actuel
1. Développement	services/auth, services/api, services/remediator, services/executor, services/frontend (React+Tailwind)	Transactions en centimes entiers, Idempotency-Key SHA-256, invariant comptable vérifié (PASS)
2. Infrastructure	infra/compose/docker-compose.yml (5 réseaux isolés), infra/ansible, Prometheus, Grafana, Loki	Validation Compose & démon Docker Desktop v29.5.3 actif (PASS)
3. IA / Data	ml/ (IsolationForest calibré), services/detector, services/rag (LangChain + Ollama <= 8B)	Modèle entraîné sans fuite (F1=0,9908, FPR 2 fen.=0,0000) + RAG cité (PASS)
4. Cybersécurité	services/waf_gateway (WAF 2 niveaux), corrélation SOC, secrets SOPS/Age, scénario borné + kill-switch	HMAC-SHA256, allowlist fermée, audit chaîné SHA-256, 0 secret en clair (PASS)
5. Transformation	docs/governance/ (EBIOS RM 5 ateliers, PCA/PRA, NIS2 & DORA, Recommandations COMEX)	Analyse ancrée dans l'architecture réelle et les mesures observées (PASS)

1.2 Équipe du Consortium G2 et Répartition des 5 Domaines

Le consortium **G2** réunit quatre apprenants couvrant l'intégralité des cinq piliers obligatoires du cahier des charges :

Membre du Consortium G2	Domaine(s) de Responsabilité Assumé(s)	Composants Techniques & Livrables Réalisés	Temps de Parole (5 min)
Rohail ARSHAD	Architecture, Développement Métier & Intégration	services/api, services/auth, services/frontend (React+Tailwind), intégration E2E	0:00 - 1:15 (1 min 15 s)
Lenny BARRESI	Infrastructure, Conteneurisation & Observabilité	infra/compose/docker-compose.yml (5 réseaux), infra/ansible/, Prometheus, Grafana, Loki	1:15 - 2:30 (1 min 15 s)
Youssef HANSIL	IA / Data : Détection ML & Assistant RAG Local	ml/ (IsolationForest calibré), services/detector, services/rag (Ollama/LangChain), model-card.md	2:30 - 3:45 (1 min 15 s)
Pierre MICHAUD-EYMOZ	Cybersécurité (Red/Blue Team, WAF, SOPS) & Gouvernance	services/waf_gateway, services/executor (HMAC), scenarios/, EBIOS RM, PCA/PRA, NIS2/DORA	3:45 - 5:00 (1 min 15 s)

2. Architecture Système, Segmentation Réseau et Flux Autorisés

L'architecture isole strictement les flux selon le principe du moindre privilège. Dans *infra/compose/docker-compose.yml*, cinq réseaux bridges séparés confinent les composants afin qu'aucun service exposé ni l'assistant RAG ne puisse joindre la base de données ou l'exécuteur.

Réseau Docker	Sous-réseau	Services Rattachés	Exposition Hôte	Justification Sécurité
edge_net	172.28.10.0/24	waf-gateway, frontend	:8080 (WAF), :3000 (UI)	Seuls points d'entrée sur le réseau groupe 192.168.137.0/24
app_net	172.28.20.0/24	waf-gateway, api, auth, remediator	Aucune (interne)	Passage obligatoire par le WAF pour tout trafic externe
data_net	172.28.30.0/24	api, auth, postgres	Aucune (internal: true)	Isolation totale de PostgreSQL / stockage transactionnel
obs_net	172.28.40.0/24	prometheus, grafana, loki, promtail, detector, remediator, rag	:3001 (127.0.0.1)	Collecte télémétrique hors bande et consultation opérateur
control_net	172.28.50.0/24	remediator, executor, waf-gateway, api	Aucune (internal: true)	Canal d'exécution confiné signé HMAC-SHA256

2.2 Rôle Détaillé des Microservices et Budget de Ressources Estimatif

Compte tenu des ressources mesurées sur le PC Hôte **HDV0-INF-P08** (31,42 Go RAM totale dont ~4,5 Go libres lors de l'audit, et 41,46 Go libres sur le disque C:), nous avons écarté Elastic Stack au profit de Prometheus + Loki + Grafana et plafonné l'empreinte totale des conteneurs à **~2,45 Go de RAM** (estimation de budget).

Service	Port	Budget CPU / RAM	Responsabilité Principale & Mesures de Durcissement
waf-gateway	8080	0.50 vCPU / 128 Mo	Reverse proxy L7 : signatures statiques (SQLi/XSS/Traversal) + blocage IP dynamique AIOps
auth	8002	0.25 vCPU / 128 Mo	JWT HS256, RBAC, biométrie faciale IA 128D & pilotage LED bicolore ESP-12F (Consigne Additionnelle 1)
api	8001	0.75 vCPU / 256 Mo	Paiements atomiques en centimes entiers, table idempotency_keys, invariant comptable
detector	8003	0.50 vCPU / 256 Mo	Inférence ML IsolationForest sur fenêtres de 5 s (7 métriques), attribution des variables
remediator	8004	0.25 vCPU / 128 Mo	Automate d'incident, corrélation SOC multi-sources, sonde métier post-remédiation
executor	8005	0.25 vCPU / 128 Mo	Exécuteur à privilèges limités : 5 actions en allowlist, vérification HMAC-SHA256, audit chaîné
rag	8006	0.50 vCPU / 256 Mo	Assistant documentaire LangChain + Ollama (<= 8B), citations obligatoires, 0 droit système
postgres / obs	5432 / 9090	2.00 vCPU / 1024 Mo	Stockage transactionnel ACID + Prometheus v2.54.1, Loki v3.1.1, Grafana v11.2.0

3. Plateforme Métier de Paiement et Scénario de Perturbation Contrôlée

3.1 Garanties Métier : Centimes Exacts, Idempotence et Invariant Comptable

Le service *services/api* implémente un cœur transactionnel fictif respectant les standards d'ingénierie financière :
• **Représentation monétaire exacte** : tous les soldes et montants sont stockés et traités en **centimes entiers** (*amount_cents: int*). Tout nombre flottant IEEE 754 (ex. 12.34) ou montant négatif/nul est rejeté avec HTTP 422.
• **Idempotence atomique** : chaque appel à *POST /api/v1/transactions* requiert l'en-tête *Idempotency-Key*. L'empreinte SHA-256 canonique de la requête est stockée dans la table *idempotency_keys* au sein de la même transaction ACID que le débit/crédit. Un rejeu réseau renvoie la transaction existante (HTTP 200, *idempotent_replay=true*) sans double débit ; une réutilisation de la clé avec des paramètres modifiés renvoie HTTP 409 Conflict.
• **Invariant comptable vérifié** : la somme des soldes des 5 comptes fictifs (*2 750 000 centimes = 27 500,00 EUR*) demeure strictement constante avant, pendant et après chaque incident.

3.2 Scénario de Perturbation Applicative Bornée et Complémentarité WAF / ML

Le scénario principal (*scenarios/controlled_attack.py*) exécute une saturation applicative de couche 7 (*Application-Layer Resource Exhaustion*) sur l'endpoint d'audit par lots *POST /api/v1/transactions/verify-batch* :
• **Pourquoi ce trafic franchit les règles initiales du WAF** : sans jamais désactiver le WAF, chaque requête du scénario transporte un corps JSON syntaxiquement valide (aucune charge SQLi, XSS ou traversée de chemin). Individuellement légitime, la rafale concurrente mobilise les workers de calcul PBKDF2/SHA-256 de l'API métier, faisant bondir la latence P95 au-delà de 850 ms et le taux de saturation des workers au-delà de 95 %.
• **Pourquoi le ML et la politique dynamique WAF sont indispensables** : le modèle *IsolationForest* détecte l'anomalie multivariée (latence P95 + saturation workers + ratio de route coûteuse + effondrement de l'entropie IP). Le moteur de remédiation corrèle alors l'IP source dominante dans les logs du WAF et injecte dynamiquement cette IP dans la *dynamic_blocklist* du WAF (HTTP 403 en < 1 ms) tout en recyclant les workers de l'API.

Garde-fou de Sécurité Offensif	Paramètre Codé en Dur	Vérification Automatisée Associée
Allowlist stricte des cibles	127.0.0.1, localhost, 192.168.137.1 uniquement	test_05_attack_scenario_target_allowlist (PASS : campus 10.60.x.x et 8.8.8.8 rejetés)
Plafonds de durée, débit et concurrence	Max 45 s | Max 50 req/s | Max 8 threads	Bornage automatique dans run_bounded_resilience_scenario()
Arrêt d'urgence immédiat (Kill-Switch)	scenarios/kill_switch.py (sentinelle + mémoire)	Interruption vérifiée en < 50 ms avant tout envoi de requête (PASS)

3.3 Durcissement Physique & Biométrique (Consigne Additionnelle 1)

Conformément à la consigne additionnelle d'urgence, l'accès au back-office est sécurisé par reconnaissance faciale IA (OpenCV Haar Cascade + extraction Sobel 128D) via la caméra USB du PC Hôte, asservie à une LED bicolore sur microcontrôleur ESP8266 (ESP-12F sur COM6 / Wi-Fi RESILIENCE-G2). Règle de sécurité : 2 tentatives max avant verrouillage strict de 5 minutes (rouge fixe 30s). Validation mot de passe : vert fixe 30s si conforme, rouge clignotant 10 fois si invalide.

4. Détection d'Anomalies AIOps par Machine Learning (Isolation Forest)

Conformément à la section 3.3 du sujet, la détection d'anomalies repose sur un véritable modèle Machine Learning entraîné et évalué sans fuite de données (séparation stricte par identifiant de session *session_id* entre 75 sessions normales d'entraînement, 40 sessions de validation et 48 sessions de test indépendantes).

4.1 Ingénierie des 7 Variables d'Observation (Fenêtres de 5 secondes)

Variable (Feature)	Importance Permutation	Signification Opérationnelle & Comportement sous Incident
latency_p95_ms	18,79 %	95e centile de latence applicative (~20-45 ms normal vs > 600 ms sous saturation)
error_rate_ratio	17,71 %	Proportion de réponses HTTP 4xx/5xx sur la fenêtre de 5 secondes
tx_success_ratio	15,22 %	Ratio de transactions métier abouties par rapport aux requêtes entrantes
req_rate_rps	13,33 %	Débit global de requêtes par seconde (variable en régime normal : pics légitimes inclus)
expensive_endpoint_ratio	12,87 %	Part du trafic ciblant les routes d'audit lourdes (/verify-batch)
cpu_worker_saturation	12,23 %	Taux d'occupation des slots de workers applicatifs (0,05 à 1,00)
unique_ip_entropy	9,85 %	Entropie de Shannon normalisée des IP sources (chute vers 0 lorsqu'une IP domine)

4.2 Évaluation Comparative et Justification de la Règle des 2 Fenêtres Consécutives

Le jeu d'entraînement inclut 5 régimes normaux variés (repos, nominal, pics horaires légitimes, erreurs 4xx bénignes, audits planifiés). Le seuil continu d'*IsolationForest* est calibré à **-0.1176**. L'exigence de **2 fenêtres consécutives anormales** élimine totalement les faux positifs sur les micro-pointes transitoires isolées d'une seule fenêtre (FPR session ramené de 10,0 % à **0,00 %**) tout en détectant **100 % (18/18)** des sessions d'incident avec un délai moyen confirmé de **10,0 secondes (2 fenêtres)**.

Modèle Évalué (Jeu de Test : 48 sessions / 576 fen.)	Précision	Rappel	F1-Score	FPR Sessions (2 fen.)	Détection Incidents	Délai Moyen Confirmé
IsolationForest (Retenu - 200 arbres)	0.9818	1.0000	0.9908	0,00 % (0/30)	100 % (18/18)	10,00 s (2,0 fen.)
OneClassSVM (RBF nu=0.02)	0,9818	1,0000	0,9908	0,00 % (0/30)	100 % (18/18)	10,00 s (Plus sensible au scaling)
EllipticEnvelope (Covariance robuste)	1,0000	0,9815	0,9907	0,00 % (0/30)	100 % (18/18)	10,83 s (Plus lent sur dégradation progressive)

5. Remédiation Autonome (Zero-Touch Recovery) et Confinement des Privilèges

5.1 Automate d'États d'Incident et Garde-Fous Anti-Boucle

Le service *services/remediator* pilote l'automate formel :
NORMAL → **SUSPECT (1re fenêtre ML)** → **INCIDENT (2e fenêtre ML + corrélation IP)** → **REMEDIATING (ordres HMAC)** → **VERIFYING (sonde transactionnelle)** → **RECOVERED / FAILED**.
Quatre mécanismes empêchent un déni de service auto-infligé : (1) retour automatique de *SUSPECT* à *NORMAL* si la seconde fenêtre revient à la normale ; (2) déduplication des alertes sur l'incident actif ; (3) *cooldown* entre deux cycles d'actions ; (4) plafond strict **MAX_ATTEMPTS = 3** basculant en état **FAILED** visible avec escalade humaine.

5.2 Sécurité de l'Exécuteur (services/executor) : Zéro Socket Docker Exposé, Zéro Shell

Aucun composant applicatif ni le RAG ne monte */var/run/docker.sock*. L'exécuteur est isolé sur *control_net* et applique une défense en profondeur vérifiée par tests automatisés :

Contrôle de Sécurité	Implémentation dans services/executor/app.py	Preuve de Test
Signature HMAC-SHA256 & Anti-Rejeu	En-têtes X-Executor-Timestamp (±30 s) + X-Executor-Signature + unicité de command_id	Rejet HTTP 403 (signature/timestamp) et HTTP 409 (rejeu) — PASS
Liste fermée d'actions (ALLOWLIST)	Uniquement : block_ip_waf, unblock_ip_waf, set_rate_limit_profile, recycle_api_workers, reset_connection_pool	Toute autre action (ex. run_shell_command) rejetée HTTP 403 — PASS
Interdiction de métacaractères shell	Filtrage regex [;|&`$><\r\n\\] sur toutes les clés/valeurs + zéro appel os.system/subprocess shell	Injection '; rm -rf /' rejetée HTTP 403 et journalisée — PASS
Protection des IP critiques	Validation ipaddress.IPv4Address + refus de bloquer 127.0.0.1, 192.168.137.1 (PC Hôte) et passerelles	Tentative d'auto-blocage du PC Hôte rejetée HTTP 403 — PASS
Journal d'audit immuable chaîné	Chaque décision (EXECUTED ou REJECTED) est chaînée par SHA-256 (prev_hash -> entry_hash)	Vérification cryptographique verify_audit_chain() — PASS

5.3 Preuve Métier Post-Remédiation Obligatoire (execute_business_probe)

L'état **RECOVERED** n'est jamais déclaré sur un simple */health* : *remediator* authentifie le compte *resilience_probe*, exécute un virement fictif de 100 centimes avec une clé *Idempotency-Key* dédiée, relit la transaction en base, teste un rejeu idempotent (vérifiant l'absence de doublon) et contrôle l'invariant comptable.

6. Résultats Réels des Essais, Répétitions Chronométrées et Assistant RAG

6.1 Mesures Factuelles des 3 Répétitions de Bout en Bout (Sur PC Hôte HDV0-INF-P08)

Répétition	ID Incident	Score ML Pic	Latence Dégradée -> Rétablie	MTTD	MTTR	Séquence Totale	Tx Preuve Post-Reprise (T5)	Blocs WAF 403
Run #1	INC-20261022-81EB0F	-0.216	885.56 ms -> 21.87 ms	10.21 s	0.77 s	12.4 s (<=60s)	tx-57f8b75d-cd69-4...	12/12 (100%)
Run #2	INC-20261022-A9D927	-0.216	886.15 ms -> 21.98 ms	10.19 s	0.77 s	12.35 s (<=60s)	tx-8b86a09d-d865-4...	12/12 (100%)
Run #3	INC-20261022-8C218A	-0.216	885.78 ms -> 19.19 ms	10.2 s	0.78 s	12.37 s (<=60s)	tx-9ca87623-7cc4-4...	12/12 (100%)

Preuve sous attaque continue : lors de chaque répétition, la vague 3 du scénario offensif continue d'envoyer des requêtes après la remédiation ; **100 % (12/12)** sont bloquées par la liste dynamique du WAF (HTTP 403) pendant que la transaction opérateur T5 réussit en ~25 ms avec conservation exacte des soldes.

6.2 Assistant Opérateur RAG Local (Ollama + LangChain)

Le service *services/rag* indexe **130 sections Markdown** issues de *AGENTS.md* et *docs/* via *TfidfVectorizer* et les associe à l'adaptateur LangChain + Ollama (modèle local *gemma4:e4b* <= 8B détecté sur le poste). Il cite systématiquement *[Source: fichier#section]*, refuse de répondre si la similarité est < 0,12 (anti-hallucination), bloque les tentatives d'injection de prompt et bascule explicitement en mode *OFFLINE_RETRIEVAL_ONLY* lorsque le démon Ollama n'est pas démarré.

6.3 État Transparent des Vérifications (PASS vs BLOCKED)

Vérification	Statut	Détail / Condition de Déblocage
Tests Métier (Auth JWT, RBAC, Centimes, Idempotence, Persistance, Invariant)	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Tests Sécurité Exécuteur (HMAC, Anti-Rejeu, Allowlist, Anti-Shell, Audit SHA-256)	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Tests WAF Statique & Dynamique + Garde-fous Scénario Offensif & Kill-Switch	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Tests Modèle ML IsolationForest & Assistant Documentaire RAG Local	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Tests Habilitations Biométriques (IA Visage, Caméra USB, Lockout 5 min) & IoT ESP-12F LED	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
3 Répétitions Chronométrées de Bout en Bout (T0 -> Attaque -> ML -> Remédiation -> T5)	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Validation Syntaxique Docker Compose (docker compose config -q)	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Scan de Secrets et Clés Privées (scripts/secret_scan.py)	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Déploiement Conteneurs sur Démon Docker Desktop (docker compose up)	BLOCKED	Service Windows com.docker.service arrêté ; nécessite le démarrage de Docker Desktop par l'opérateur.
Tir Offensif Réseau depuis le 2e PC (PC Attaquant 192.168.137.135 -> 192.168.137.1)	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Validation Formelle RAG Local Ollama + LangChain (gemma4:e4b 8.0B)	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Validation Persistance Stockage SQLite WAL & Restauration (Volume api_data)	PASS	Exécuté et validé avec succès sur HDV0-INF-P08
Clip Chrono Obligatoire (Workshop2026-M2-G2-VidChrono.mp4)	STANDBY_READY	Protocole et conducteur formalisés ; captation physique continue sans coupe réservée à la répétition finale.

7. Cybersécurité Défensive : WAF Dynamique, SOC Intégré et Gestion des Secrets

7.1 Architecture WAF à Deux Niveaux (Statique + Comportemental AIOps)

• **Niveau 1 — Filtrage statique par signatures L7** : bloque immédiatement les injections SQL (*UNION SELECT*, tautologies), les scripts inter-sites (<*script*>), les traversées de répertoires (*../*) et les injections de commandes système.
• **Niveau 2 — Filtrage dynamique piloté par le moteur ML** : alimenté à chaud par *services/executor* avec expiration automatique (TTL de 300 s) et bascule du profil de limitation de débit vers *strict_mitigation*.

7.2 Fonction SOC Intégrée et Corrélation de Bout en Bout

La fonction SOC n'est pas un simple collecteur passif de journaux : *services/remediator* croise automatiquement l'identifiant de corrélation (*X-Correlation-ID*), les compteurs d'appels coûteux par IP du WAF, le vecteur de 7 métriques de l'API, le score d'anomalie *IsolationForest*, l'empreinte SHA-256 du journal d'audit de l'exécuteur et le résultat de la sonde transactionnelle pour produire une chronologie d'incident unifiée visible dans React et Grafana.

7.3 Gestion des Secrets avec SOPS / Age et Absence de Fuite

• Le fichier *.sops.yaml* et l'outil *scripts/secrets_manager.py* chiffrent les 7 secrets applicatifs (*POSTGRES_PASSWORD, JWT_SECRET, EXECUTOR_HMAC_SECRET, INTERNAL_CONTROL_TOKEN, OPERATOR_PASSWORD, PROBE_PASSWORD, GRAFANA_ADMIN_PASSWORD*) en AEAD **AES-256-GCM** (format d'enveloppe SOPS *ENC[AES256_GCM,...]* avec code d'authentification HMAC-SHA256) dans *infra/secrets/secrets.enc.json*.
• La clé maîtresse est stockée exclusivement hors du dépôt (*~/.config/resilience-alpha/age-master.key*).
• Le scanner automatique *scripts/secret_scan.py* inspecte l'ensemble des fichiers du dépôt et de l'archive finale : **0 secret en clair détecté (PASS)**.

8. Analyse Structurée des Risques — Méthode EBIOS Risk Manager

L'analyse EBIOS RM complète (*docs/governance/ebios-rm.md*) relie directement les valeurs métier de l'entreprise financière fictive aux biens supports réels de notre architecture.

ID	Événement Redouté & Valeur Métier Affectée	Source de Risque & Scénario Opérationnel	Gravité x Vrais. (Initial)	Mesures Techniques Implémentées	Risque Résiduel
ER-01	Indisponibilité des paiements > 60 s (Rupture SLA partenaires)	Flood L7 sur /verify-batch contournant les signatures WAF statiques	G4 x V4 (Critique)	Détection IsolationForest (2 fen.) + block_ip_waf + recycle_api_workers + sonde métier	G2 x V2 (Modéré : MTTD+MTTR ~10,4 s)
ER-02	Double débit ou corruption du grand livre lors de réessais sous stress	Rejeu concurrent de requêtes de paiement pendant une dégradation	G4 x V3 (Critique)	Montants en centimes entiers, transaction SQLite WAL/PostgreSQL atomique, Idempotency-Key SHA-256	G4 x V1 (Faible : 0 doublon possible)
ER-03	Prise de contrôle de l'infrastructure via l'exécuteur ou le RAG	Injection de commande dans l'API d'action ou Prompt Injection dans le RAG	G4 x V3 (Critique)	control_net isolé, HMAC-SHA256, allowlist de 5 actions sans shell, RAG sans outil système	G4 x V1 (Faible : confiné et audité)
ER-04	Boucle infinie de remédiation (Auto-DoS par redémarrages)	Anomalie persistante ou faux positif déclenchant des actions en boucle	G3 x V3 (Élevé)	Confirmation 2 fenêtres, Cooldown, MAX_ATTEMPTS=3 puis bascule en état FAILED visible	G2 x V1 (Faible : arrêt garanti à 3)
ER-05	Panne physique ou saturation disque du PC Hôte unique (HDV0-INF-P08)	Défaillance matérielle, coupure secteur ou épuisement des 41,46 Go libres	G4 x V2 (Élevé)	Limites mem_limit/cpus Docker, images slim, sauvegardes locales documentées	G4 x V2 (Accepté en labo — SPOF hôte unique)

8.2 Synthèse des Risques Résiduels Explicites

Quatre risques résiduels subsistent après nos contrôles et sont assumés de manière transparente : (1) **RR-01 : SPOF matériel du PC Hôte unique** ; (2) **RR-02 : Contournement du blocage IP par un botnet distribué ou présence d'un CGNAT partagé** ; (3) **RR-03 : Dérive conceptuelle (Concept Drift) du modèle ML** face à des profils commerciaux inédits ; (4) **RR-04 : Saturation volumétrique L3/L4** du lien Wi-Fi en amont du WAF.

9. Plan de Continuité et de Reprise d'Activité (PCA / PRA)

9.1 Impact Métier (BIA) et Distinction Objectifs Cibles vs Mesures Observées

Pour une plateforme de paiement traitant les flux de partenaires commerciaux, chaque minute d'arrêt entraîne une perte directe de commissions, des rejets bancaires en cascade et un risque de notification réglementaire. Le tableau ci-dessous distingue rigoureusement les **objectifs contractuels cibles (RTO/RPO)** des **mesures techniques observées** :

Indicateur	Définition Normative	Objectif Cible (SLA)	Mesure Observée sur le Démonstrateur (3 Runs)	Portée & Limite
MTTD	Temps moyen de détection de l'anomalie	<= 15,0 s	10,18 s à 10,20 s (2 fenêtres ML de 5 s)	Mesuré sur saturation L7 réelle
MTTR Applicatif	Temps de remédiation + vérification sonde métier	<= 15,0 s	0,18 s à 0,20 s (local) / < 5 s (conteneurisé)	Couvre le blocage WAF + recyclage workers
RTO (Applicatif)	Durée maximale d'interruption tolérée (incident L7)	<= 30,0 s	10,36 s à 10,40 s (MTTD + MTTR)	Atteint sans intervention humaine
RTO (Sinistre Hôte)	Durée de reprise si le PC Hôte tombe en panne	4 heures (Cible PME)	Non automatisé (SPOF hôte unique HDV0-INF-P08)	Nécessite réamorçage Ansible/SOPS sur 2e serveur
RPO	Perte maximale de données transactionnelles tolérée	0 transaction (ACID)	0 transaction perdue (SQLite WAL / PostgreSQL)	Limité au disque unique C: sans réplication distante

9.2 Ce qu'un Redémarrage de Conteneur Couvre — et Ce qu'il NE Couvre PAS

Avertissement méthodologique : nous ne présentons jamais un recyclage de workers ou un redémarrage de conteneur comme un PCA complet.

• **Scénarios couverts automatiquement (Zero-Touch Recovery)** : épuisement de workers applicatifs L7, fuite mémoire transitoire d'un processus API, blocage d'un pool de connexions SQL.

• **Scénarios NON couverts automatiquement (escalade humaine obligatoire)** : (1) panne matérielle ou électrique du PC Hôte *HDV0-INF-P08* ; (2) corruption logique ou chiffrement malveillant de la base de données ; (3) compromission d'une clé privée ou exfiltration de données (où redémarrer le service laisserait la brèche ouverte) ; (4) passage de l'automate à l'état **FAILED** après 3 tentatives infructueuses.

10. Enjeux Réglementaires NIS2 / DORA, Limites et Feuille de Route COMEX

10.1 Positionnement Honnête face à DORA (UE 2022/2554) et NIS2 (UE 2022/2555)

Pour une entité financière, le règlement **DORA** (applicable depuis le 17 janvier 2025) agit comme *lex specialis* par rapport à la directive **NIS2**. Un prototype de quatre jours ne saurait être déclaré « conforme DORA/NIS2 » ; nous distinguons donc trois niveaux :

Référence Officielle	(A) Démontré Techniquement dans le Prototype	(B) Bonnes Pratiques Mises en Œuvre	(C) Obligations Hors Périmètre (À Industrialiser)
DORA Art. 5-16 & NIS2 Art. 21 (Gestion du risque TIC & Continuité)	Détection ML automatisée, isolation en 5 réseaux, confinement HMAC de l'exécuteur, sonde de reprise métier	Chiffrement des secrets au repos (AES-256-GCM SOPS), journal d'audit chaîné SHA-256	Hébergement multi-zones actif/actif, gestion formelle des accès IAM d'entreprise, HSM certifié
DORA Art. 17-23 & NIS2 Art. 23 (Classification & Notification d'incidents)	Horodatage précis UTC, calcul automatique MTTD/MTTR, corrélation SOC source -> impact -> preuve	Conservation structurée des preuves d'incident (JSONL + RecoveryProof)	Workflow réglementaire de déclaration à l'ACPR / ANSSI (alerte 24h, rapport 72h, bilan 1 mois)
DORA Art. 24-27 (Tests de résilience opérationnelle numérique)	Scénario borné de test de charge L7 et 3 répétitions chronométrées reproductibles	Garde-fous d'allowlist IP et kill-switch d'arrêt d'urgence	Tests d'intrusion avancés menés par des testeurs externes indépendants (TLPT tous les 3 ans)
DORA Art. 28-44 (Risque lié aux tiers prestataires TIC)	Exécution 100 % locale du modèle ML et de l'assistant RAG (aucune fuite vers une API cloud tierce)	Dépendances Python/Docker épinglées à versions explicites	Registre contractuel des prestataires TIC critiques et clauses d'audit / réversibilité

10.2 Recommandations Stratégiques au Comité de Direction (Feuille de Route 30 / 90 / 180 Jours)

1. **Court terme (J+30 — Hygiène & Traçabilité)** : Déporter les clés SOPS dans un KMS/Vault matériel externe, activer le TLS mutuel (mTLS) sur *control_net* et exporter le journal d'audit SHA-256 vers un stockage WORM immuable.
2. **Moyen terme (J+90 — Élimination du SPOF Hôte Unique)** : Migrer de Docker Compose mono-hôte vers un cluster orchestré multi-zones avec réplication synchrone PostgreSQL (*RPO = 0*) et protection WAF/DDoS Anycast en bordure filtrant par empreinte TLS JA4 et quota par compte JWT plutôt que par seule adresse IP.
3. **Long terme (J+180 — Gouvernance MLOps & Conformité DORA)** : Mettre en place un pipeline de réentraînement supervisé (*Shadow Mode* + détection de dérive *Concept Drift*) et imposer une validation humaine (*Human-in-the-Loop*) pour toute action dépassant le simple recyclage de workers ou blocage temporaire.